GED sécurisée — Agence de Promotion des Investissements du Cameroun

Plateforme de **Gestion Électronique de Documents** (GED) et de **site public bilingue** (français / anglais) de l'Agence de Promotion des Investissements du Cameroun (API).

Elle réunit, dans une seule application :

- le **site public** de l'Agence : accueil, missions, services, actualités, contact ;
- l'**Espace Agents**, protégé par double authentification : documents, messagerie interne, signatures, archivage, journal d'audit.

La plateforme repose sur des outils libres (**Next.js**, **Supabase / PostgreSQL**) et s'héberge sur **Vercel**. Elle partage son code et sa base de données avec le déploiement de démonstration « KHS Bank » : chaque organisation est cloisonnée par la base elle-même (voir le guide *guide-multi-organisation.md*).

1. Ce que la plateforme apporte à l'Agence

Besoin de l'Agence	Réponse de la plateforme
Présenter l'Agence aux investisseurs, en français et en anglais	Site public bilingue : missions, services, actualités, formulaire de contact
Ne pas laisser circuler des documents sensibles	Classification *public interne* / *restreint* / *confidentiel*, appliquée par la base de données
Savoir qui a fait quoi, sans pouvoir effacer les traces	Journal d'audit immuable (aucune modification ni suppression possible)
Produire et valider des documents officiels	Éditeurs Word, Excel et PowerPoint en ligne, export PDF, circuit *dépôt* → *vérification* → *validation* → *publication*
Authentifier les actes du Directeur Général	Signature numérique du DG : spécimen, cachet, QR code, page de vérification publique
Conserver les archives selon des règles	Archivage scellé (empreinte SHA-256), lecture seule définitive, durées de conservation par nature de document
Échanger en interne sans messagerie externe	Messagerie interne : conversations, groupes, canaux par département, pièces jointes contrôlées
Protéger les comptes des agents	Double authentification obligatoire (Google Authenticator)

2. Les rôles

Tout nouvel agent reçoit le rôle `lecteur` (principe du moindre privilège). Seul un administrateur de l'Agence peut le modifier.

Rôle	Ce qu'il peut faire
`lecteur`	Consulter les documents publiés auxquels il a droit
`redacteur`	Déposer, rédiger et faire évoluer des documents de son département
`validateur`	Vérifier, valider, publier et archiver les documents de son département
`administrateur`	Gérer les agents et leurs rôles, le site public, les modèles, l'archivage, les signatures
`auditeur`	Consulter le journal d'audit et vérifier les documents, sans jamais les modifier

Les rôles, les départements et l'organisation de chaque agent sont **appliqués par PostgreSQL** (*Row Level Security*) : même un accès direct à l'API de la base resterait soumis aux mêmes règles. Un agent de l'Agence ne voit jamais les données d'une autre organisation.

---

3. Fonctionnalités de l'Espace Agents

3.1 Documents et ateliers documentaires

- Référence unique attribuée par la base (ex. `API-2026-000123`), jamais saisie ni modifiable.
- Chaque document porte une **nature** (note de service, courrier, contrat…) qui fixe sa durée de conservation.
- Un **brouillon** est privé : seuls son auteur et les personnes avec qui il l'a partagé le voient.
- Éditeurs **Word, Excel, PowerPoint** dans le navigateur, modèles bilingues, export en PDF.
- **Nouvelle version** (v2, v3…) pour corriger un document publié ou archivé.
- **Recherche plein texte** (titre, référence, description, contenu) limitée à ce que l'agent a le droit de lire.

3.2 Signature du Directeur Général

- Spécimen de signature et cachet enregistrés une fois, protégés.
- Le PDF signé porte un **bloc de signature** et un **QR code** unique.
- Page publique **/verifier** : toute personne (partenaire, investisseur, administration) peut contrôler l'authenticité d'un document en saisissant le code ou en déposant le fichier.
- Qualités, titulaires et délégations de signature gérés par l'administrateur ; registre complet.
- La signature exige une seconde authentification récente.

3.3 Archivage réglementé

- Archivage d'un document publié par le validateur ou l'administrateur, ou automatique après *N* mois (12 par défaut, réglable).
- Un document archivé est en **lecture seule définitive**, même pour l'administrateur ; son empreinte SHA-256 est scellée à l'archivage.

3.4 Messagerie interne

- Conversations privées, groupes de travail, canaux officiels et canaux par département.
- Accusés de lecture, présence, transfert, sourdine, recherche.
- Analyse antivirus des pièces jointes ; alertes par e-mail ; rétention de 3 ans.

3.5 Site public et communication

- Pages **Accueil, Missions, Services, Actualités, Contact**, en français et en anglais.
- L'administrateur publie les actualités (avec image) et lit les messages reçus par le formulaire de contact, depuis l'Espace Agents.

---

4. Sécurité — les points à retenir

- **Aucune logique d'autorisation dans le code de l'application** : c'est PostgreSQL qui filtre les résultats selon le rôle, le département et l'organisation.
- **Double authentification obligatoire** (TOTP) : sans code à 6 chiffres, un agent ne peut rien lire ni modifier, même en appelant directement l'API.
- **Journal d'audit immuable** : un déclencheur refuse toute modification ou suppression, y compris avec la clé de service.
- **Fichiers** : chaque téléchargement passe par une URL signée valable 5 minutes, jamais par un lien public permanent.
- **Cloisonnement par organisation** : la valeur est posée par la base, jamais par le navigateur.
- **Droits minimaux** : chaque table déclare ses `GRANT` explicites (jamais de `DELETE` sur les documents ni sur le journal d'audit).

---

5. Mise en service

5.1 Supabase (projet partagé)

1. Dans le projet Supabase existant, ouvrir **SQL Editor** et exécuter dans l'ordre les fichiers de `supabase/migrations/` (`0001` à `0028`). Ne rejouer que ceux qui manquent.
2. **Authentication → URL Configuration → Redirect URLs** : ajouter l'adresse du site de l'Agence (`https://api-cameroun-ged.vercel.app/**`) à côté de celle des autres organisations.
3. **Authentication → Multi-Factor** : « TOTP (App Authenticator) » activé.

5.2 Premier administrateur de l'Agence

1. Créer un compte depuis la page `/login` du site de l'Agence (le profil reçoit automatiquement l'organisation `API`).
2. Le promouvoir une seule fois dans **SQL Editor** : `sql update public.profiles set role = 'administrateur' where id = (select id from auth.users where email = 'adresse@exemple.cm');`
3. Il gère ensuite lui-même les rôles des agents, depuis la page *Utilisateurs*.

5.3 Vercel (projet de l'Agence)

Importer le dépôt GitHub, définir `Root Directory` sur `platform`, puis renseigner :

Variable	Valeur pour l'Agence
`NEXT_PUBLIC_SUPABASE_URL`, `NEXT_PUBLIC_SUPABASE_ANON_KEY`	celles du projet Supabase
`SUPABASE_SERVICE_ROLE_KEY`	clé secrète du projet Supabase (jamais exposée au navigateur)
`CRON_SECRET`	valeur aléatoire longue (purge nocturne)
`NEXT_PUBLIC_SITE_URL`	`https://api-cameroun-ged.vercel.app`
`NEXT_PUBLIC_ORG_SIGLE`	`API`
`NEXT_PUBLIC_ORG_NOM` / `NEXT_PUBLIC_ORG_NOM_EN`	nom de l'Agence en français / en anglais
`NEXT_PUBLIC_ORG_LOGO_URL`	`/logos/logo-agence-investissement-cameroun.png`
`NEXT_PUBLIC_ORG_COULEUR_PRIMAIRE` / `_ACCENT`	bleu et jaune du logo
`NEXT_PUBLIC_ORG_COULEUR_RUBAN`	vert, rouge, jaune (couleurs du drapeau)
`NEXT_PUBLIC_ORG_SITE_PUBLIC`	`true`
`RESEND_API_KEY`, `RESEND_FROM_EMAIL`	optionnel : alertes par e-mail
`CLOUDMERSIVE_API_KEY`	optionnel : seconde couche antivirus

> Les variables `NEXT_PUBLIC_*` sont figées à la construction : après modification, **redéployer**.

5.4 Lancer en local

```
cd platform
npm install
cp .env.local.example .env.local   # renseigner les variables ci-dessus
npm run dev                        # http://localhost:3000
```

---

6. Parcours de recette conseillé

1. Créer un rédacteur et un validateur dans le même département, un rédacteur dans un autre, un auditeur ; se promouvoir administrateur.
2. Le rédacteur dépose un document **confidentiel** : seuls lui, le validateur de son département, l'administrateur et l'auditeur le voient.
3. Le rédacteur le soumet ; le validateur le **valide** puis le **publie**.
4. L'administrateur fait **signer** le document par le Directeur Général ; vérifier le QR code sur la page publique `/verifier`.
5. Le validateur **archive** le document ; constater qu'aucune modification n'est plus possible.
6. Consulter le **journal d'audit** : chaque étape y figure, sans possibilité de l'effacer.
7. Avec un compte d'une autre organisation, vérifier qu'aucune donnée de l'Agence n'est visible.

---

7. Limites assumées

- **Pas de filtrage DLP automatique** (étiquettes de sensibilité automatiques, Microsoft Purview) : la classification est posée par l'agent et appliquée par la base.
- **Antivirus ciblé** : les contrôles intégrés (type réel du fichier, exécutables cachés, macros, JavaScript dans un PDF) complètent Cloudmersive mais ne remplacent pas un moteur généraliste.
- **Transfert de message limité au texte** ; **ajout de participants à un groupe uniquement à la création**.
- **Une adresse e-mail = un compte** : l'authentification est partagée entre organisations.
- **Hébergement** : actuellement sur Vercel et Supabase (cloud). Le rapatriement au Cameroun fait l'objet des propositions d'architecture A, B et C présentées à l'Agence.